

CVE Report — Dependency Scan (Post-Remediation)

Project: **vulnerable-invoice-service** · Stage 1 (OWASP Dependency-Check + Maven) · Generated 2026-06-23 · Branch: `fix/depSCAN-20260623-061718`

Summary

Metric	Before Remediation	After Remediation
Total CVEs found	28	10
CRITICAL CVEs	6	0
HIGH CVEs	11	7
MEDIUM CVEs	9	3
Supply-chain alerts	2	0
CVEs cleared this run	—	18

CVEs Cleared by this PR

Dependency	Old Version	New Version	CVEs Cleared
org.apache.logging.log4j:log4j-core	2.14.1	2.17.1	CVE-2021-44228 (10.0), CVE-2021-45046 (9.0), CVE-2021-44832 (6.6), CVE-2021-45105 (5.9)
org.apache.logging.log4j:log4j-api	2.14.1	2.17.1	CVE-2021-44228, CVE-2021-45046 (lockstep)
com.fasterxml.jackson.core:jackson-databind	2.9.8	2.18.4	CVE-2019-14379 (9.8), CVE-2019-14540 (9.8), CVE-2019-14892 (9.8), CVE-2020-36518 (7.5), CVE-2022-42003 (7.5), CVE-2022-42004 (7.5), CVE-2023-35116 (4.7), CVE-2018-1000873 (6.5 transitive)
commons-io:commons-io	2.4	2.14.0	CVE-2021-29425 (4.8), CVE-2024-47554 (4.3)
com.fastxml.jackson.core:jackson-databind	REMOVED	—	Supply-chain CRITICAL (typosquat)
http://insecure-mirror.example.net/maven2	REMOVED	—	Supply-chain HIGH (untrusted HTTP repo)

Remaining CVEs (Requires Human Follow-up)

MAJOR_REVIEW — **guava 24.1.1-jre**: CVE-2023-2976 (CVSS 7.1), CVE-2020-8908 (CVSS 3.3) — fix requires guava 32.0.0-jre (major version jump 24 → 32). Opened as tracking issue.

INEFFECTIVE — **mysql-connector-java 8.0.33**: CVE-2023-22102 (CVSS 8.3) — persists through all 8.0.x versions. Oracle advisory states fix requires 8.2.0+. Flagged for MAJOR_REVIEW.

INEFFECTIVE — **commons-lang3 3.17.0**: CVE-2025-48924 (CVSS 5.3) — uncontrolled recursion. No cleared fix version available in 3.x per NVD data at scan time.

CVE	Dependency	Current Version	CVSS	Severity	Required Fix	Status
CVE-2026-34479	log4j-core + log4j-api	2.17.1	7.5	HIGH	2.26.0	MAJOR_REVIEW
CVE-2026-34480	log4j-core	2.17.1	7.5	HIGH	2.26.0	MAJOR_REVIEW
CVE-2026-34477	log4j-core + log4j-api	2.17.1	5.9	MEDIUM	2.26.0	MAJOR_REVIEW
CVE-2025-68161	log4j-core	2.17.1	4.8	MEDIUM	2.24.3	MAJOR_REVIEW
CVE-2023-22102	mysql-connector-java	8.0.33	8.3	HIGH	8.2.0+	INEFFECTIVE
CVE-2024-7254	protobuf-java (transitive)	3.21.9	7.5	HIGH	3.25.5	Transitive of mysql
CVE-2023-2976	guava	24.1.1-jre	7.1	HIGH	32.0.0-jre	MAJOR_REVIEW
CVE-2020-8908	guava	24.1.1-jre	3.3	LOW	32.0.0-jre	MAJOR_REVIEW
CVE-2025-48924	commons-lang3	3.17.0	5.3	MEDIUM	Unknown	INEFFECTIVE

Supply-Chain Status

Alert	Status
Typosquat: com.fastxml.jackson.core	CLEARED — removed from pom.xml
Untrusted HTTP repo: insecure-mirror.example.net	CLEARED — removed from pom.xml

License Status

Dependency	License	Status
mysql:mysql-connector-java:8.0.33	GPL-2.0	OPEN — requires human decision: Oracle commercial exception or migrate to MariaDB Connector/J (LGPL-2.1)

Machine-readable source: `depscan-report.json` . Generated by the Dependency & Supply-Chain Plugin — Stage 3 (Post-Remediation CVE Report).